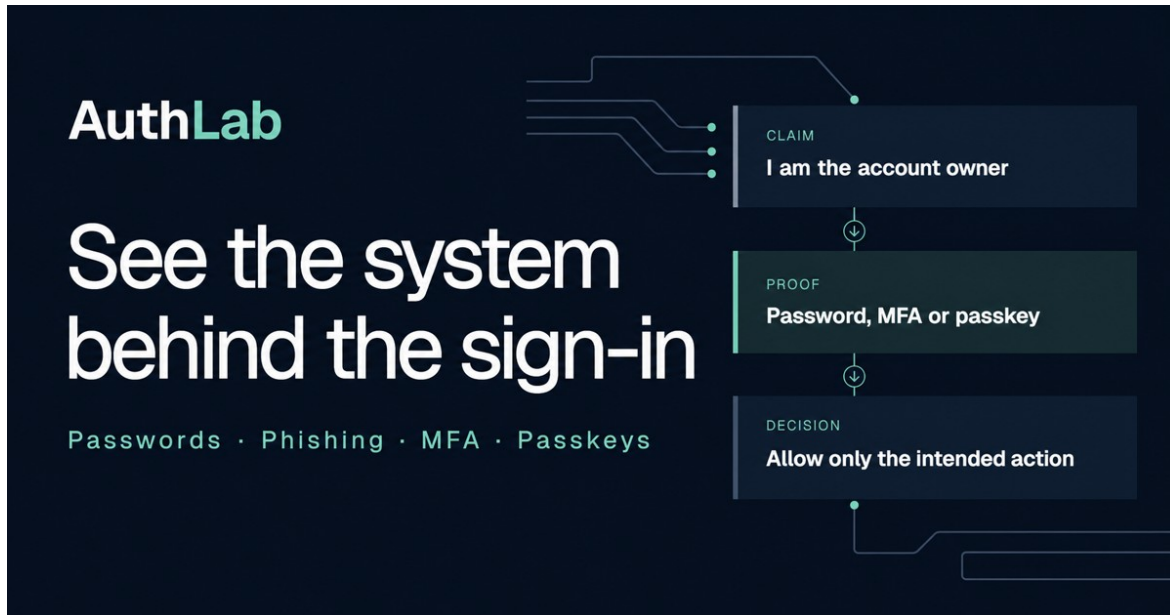


INTERACTIVE SECURITY GUIDE

AuthLab Learner Workbook

Passwords · phishing · MFA · passkeys



Course COMP6441 Security Engineering

Student Name: _____ zID: _____

Audience Beginners; no prior security or programming knowledge required

Prepared 20 July 2026

Safety first

Use only the fictional examples in this workbook and the website. Never enter or disclose a real password, MFA code, recovery answer or account identifier.

How to use this workbook

Complete the pre-test before opening the four learning modules. Record short explanations in your own words. After the modules, complete the post-test and compare not only the score but also the quality of your reasoning. The complete activity normally takes 25–35 minutes.

Learning objectives

- Separate identity, authentication and authorisation.
- Trace how a reused password creates cross-service risk.
- Use verifier/domain evidence to respond to phishing.
- Compare authenticator mechanisms against replay and phishing.
- Explain the public-key and origin-binding ideas behind passkeys.

Working vocabulary

Term	Plain-language meaning
Claim	The identity or account a person says they control.
Authenticator	The thing or mechanism used to prove control.
Verifier	The system that checks the proof.
Relying party (RP)	The website or service relying on the authentication result.
Replay	Using captured authentication evidence again.
Relay	Passing evidence to the real service in real time while deceiving the user.
Origin	The scheme, host and port that identify the web context.
Credential stuffing	Trying breached username/password pairs on other services.
Passkey	A FIDO public-key credential used for passwordless or password-replacing sign-in.

Pre-test

Choose one answer for each question. Do not look up the answer yet.

1. Authentication primarily answers:

- ☐ A. What may this account do?
- ☐ B. Can the claimant prove control of an accepted authenticator?
- ☐ C. Which data should be deleted?

2. Why can one leaked password compromise another website?

- ☐ A. Password reuse lets an attacker replay the same proof
- ☐ B. Browsers copy databases automatically
- ☐ C. Encryption stops working after a breach

3. Which clue most directly identifies the verifier in a web sign-in?

- ☐ A. The logo
- ☐ B. The registered domain/origin
- ☐ C. The colour scheme

4. A TOTP code is short-lived. Why can it still be phished?

- ☐ A. It may be relayed to the real service before expiry
- ☐ B. It is always stored in plain text
- ☐ C. It contains the password

5. What does a passkey relying party normally store?

- ☐ A. The private key
- ☐ B. A public key and credential metadata
- ☐ C. The user's biometric image

6. What property makes WebAuthn phishing resistant?

- ☐ A. Longer usernames
- ☐ B. Origin/RP binding verified through the ceremony
- ☐ C. A hidden login button

Pre-test score

____ / 6. Keep this score private unless you have agreed to anonymous evaluation.

Module 1 • Three different decisions

A/ AuthLab Learn Phishing Passkeys Results Local-only session

01 IDENTITY ENGINEERING

A login is three decisions, not one

Confusing identity, authentication and authorisation produces systems that prove the wrong thing or grant too much access.

THE CLAIM	THE PROOF	THE PERMISSION
Identity A record says Alex owns account 1042.	Authentication Alex demonstrates control of an accepted authenticator.	Authorisation Policy lets account 1042 read one course, not the admin console.

ENGINEERING TAKEAWAY

The AuthLab identity, authentication and authorisation activity.

Stage	Question	Example
Identity claim	Which account is being referred to?	student@example.test
Authentication	What proof will the verifier accept?	Passkey assertion
Authorisation	What may the authenticated account do?	Read a grade, not change all grades

Activity

For each situation, label the main failure as identity, authentication or authorisation.

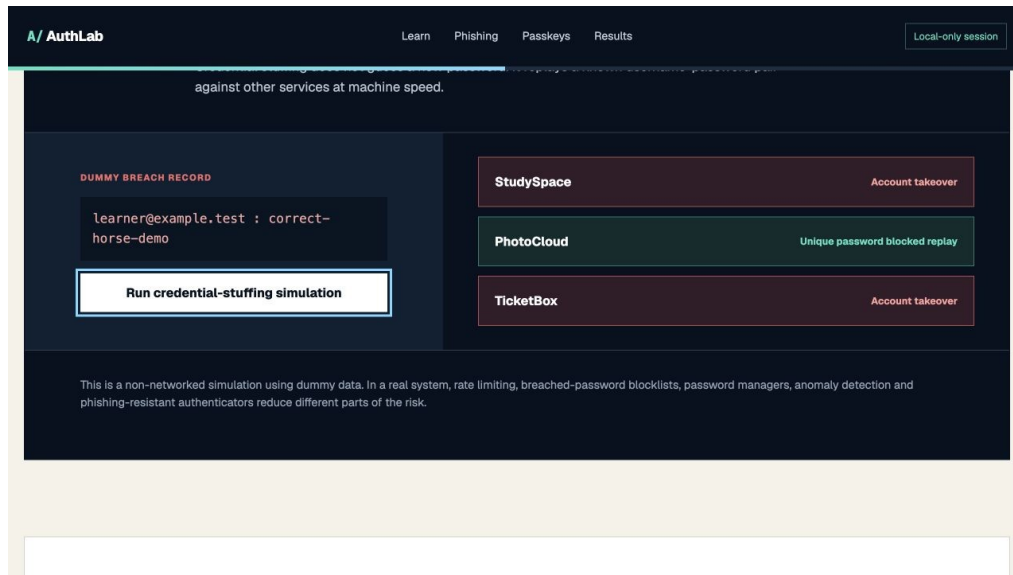
1. A help desk attaches a recovery phone number to the wrong student record:

2. A phishing page relays a one-time code to the legitimate service: _____

3. A teaching assistant account can delete every course in the university: _____

Explain why a valid authentication event does not automatically mean the requested action should be allowed:

Module 2 • Password reuse propagates a breach



Safe credential-stuffing simulation using dummy services.

Trace the attack

Step	What happens	Control that changes the outcome
1	A credential pair is exposed at Service A	Secure storage, breach detection and notification
2	An attacker automates trials at Services B and C	Rate limits, bot detection and risk signals
3	A reused password is accepted	Unique passwords or non-replayable credentials
4	The account is used for an authorised action	Least privilege, monitoring and transaction checks

Reflection

Why is 'make the password more complex' an incomplete response to credential stuffing?

Name one password control and one system control that address different parts of the attack:

Password control: _____

System control: _____

Module 3 • Phishing is a verifier problem

For each message, record the registered domain or trusted path you would use, then choose the safer action. The examples are fictional.

Scenario	Decisive evidence	Safer action
University storage warning	A message says your files will be deleted today and links to unsw-storage-support.example.test.	Open the known university portal independently; do not sign in through the message.
Payroll update	A chat message from a familiar display name requests immediate bank-detail confirmation.	Verify through the official HR system or a known contact channel.
MFA expiry	A page with a correct logo asks for password and TOTP at login-security-check.example.test.	Stop; inspect the domain and use a trusted bookmark/app.
Shared document	A document notification opens a consent page requesting broad mailbox access.	Inspect the application name, publisher and requested permissions; decline/report if unexpected.

Decision prompts

- Which exact origin or application is asking for proof?
- Does the action match the context?
- Can you reach the service through a trusted route?
- What should be reported, and where?

Write one reason that 'the logo looks correct' is weak evidence:

Module 4 • MFA and passkeys

Mechanism	Replay resistance	Phishing resistance	Residual risk
Password	No	No	Reuse, disclosure and guessing
SMS OTP	Limited	No	Relay, telecom and recovery
TOTP	Short-lived output	No	Real-time relay
Push approval	Usually	Not inherent	Fatigue and weak context
Passkey/WebAuthn	Yes	Yes	Device, recovery and ecosystem

Passkey ceremony

1. The relying party sends a fresh challenge and credential options through the browser.
2. The browser and authenticator scope the operation to the current relying party/origin.
3. The authenticator performs local user presence or verification according to policy.
4. The authenticator signs the challenge with the private key; the private key does not leave it.
5. The relying party checks challenge, origin/RP binding, flags and signature using the public key.

Check your explanation

Complete the sentence: a passkey resists a look-alike phishing domain because

Name one risk passkeys reduce and one risk they do not remove:

Reduced: _____

Remaining: _____

Precise claim

Origin-bound public-key authentication improves phishing resistance. It does not remove device compromise, recovery risk, excessive authorisation or malicious service logic.

Post-test

Answer without looking at the pre-test. The concepts match, but the wording and order differ.

1. A valid user proves control but is allowed to edit every account. Which layer failed?

- ☐ A. Identity
- ☐ B. Authentication
- ☐ C. Authorisation

2. What makes password reuse dangerous after one service is breached?

- ☐ A. The same replayable proof may be accepted elsewhere
- ☐ B. Every browser shares cookies
- ☐ C. Password length becomes zero

3. A page perfectly copies a bank's design. What evidence still matters most?

- ☐ A. The registered domain/origin and trusted route
- ☐ B. The logo size
- ☐ C. The background colour

4. Which statement about TOTP is most accurate?

- ☐ A. It cannot be phished
- ☐ B. It can be relayed before it expires
- ☐ C. It is a public key

5. Where should a passkey private key remain?

- ☐ A. With/protected by the authenticator
- ☐ B. In the email message
- ☐ C. Printed in the URL

6. What does verifier-name binding achieve?

- ☐ A. It binds authentication output to the intended relying party
- ☐ B. It hides the username font
- ☐ C. It forces monthly password changes

Post-test score

____ / 6. Change from pre-test: ____ . A score change is only one form of evidence; explanation quality and recurring misconceptions also matter.

Facilitator evaluation protocol

Before the session

- Use 3–5 adult volunteers from the stated beginner audience unless your course provides a different requirement.
- Explain that participation is voluntary and educational; do not record names, emails, account identifiers or demographic data unless specifically approved.
- Tell participants never to enter real credentials. Verify that only fictional examples are visible.
- Assign random codes such as P01 and keep no key that links codes to identities.

Observation sheet

Code	Pre /6	Post /6	Key misconception	Usability note
P__				
P__				
P__				
P__				
P__				

Short anonymous feedback

- The activity that changed or clarified my understanding most was:

- One term or explanation that remained confusing was:

- I could explain why a passkey resists phishing: 1 2 3 4 5
- The site was easy to navigate: 1 2 3 4 5
- One improvement I recommend:

Reporting rule

Report zero, negative and positive changes. A small convenience sample can reveal problems, but it does not prove general effectiveness.

Answer key and teaching notes

Item	Correct answer	Teaching note
Pre 1 / Post 1	B / C	Authentication checks proof; authorisation controls permitted action.
Pre 2 / Post 2	A / A	Reuse allows a captured password to be replayed at another verifier.
Pre 3 / Post 3	B / A	Visual appearance is copyable; origin/domain and trusted route identify context.
Pre 4 / Post 4	A / B	A short lifetime reduces replay window but does not stop real-time relay.
Pre 5 / Post 5	B / A	The RP has public-key material; the authenticator protects the private key.
Pre 6 / Post 6	B / A	WebAuthn binds output to the intended RP/origin through the ceremony.
Module 1 cases	Identity / Authentication / Authorisation	Recovery record, relayed proof and excessive privilege fail at different layers.

Suggested explanations

Password complexity alone is incomplete because a strong reused password remains a reusable bearer secret. A password manager and unique passwords reduce reuse; rate limiting, breached-password blocklists and anomaly detection address system-side risk. Passkeys change the protocol by replacing a shared/replayable secret with scoped public-key credentials.

A passkey resists a look-alike phishing domain because the browser/authenticator ceremony binds the credential to the legitimate relying party. The phishing origin cannot request a valid assertion for the legitimate RP simply by copying its interface.

Primary references

NIST SP 800-63B: [Official source](#)

W3C WebAuthn Level 3: [Official source](#)

FIDO Alliance Passkeys: [Official source](#)

OWASP Credential Stuffing: [Official source](#)

CISA Phishing Guidance: [Official source](#)

Personal reflection and completion record

Complete this page after the activity. These responses should be your own; they are not generated by the website.

Before this activity, I thought authentication security depended mainly on ...

The most important technical distinction I can now explain is ...

A mistake or confusing point I encountered was ...

I resolved it by checking / testing / comparing ...

One limitation of the project or evaluation is ...

If I extended this work, I would ...

Completion checklist

☐ Pre-test ☐ Four modules ☐ Post-test ☐ Anonymous export (if participating) ☐ Reflection ☐ No real credentials disclosed